

Welcome to

Web Attacks II – Tools, Labs & Defence

Saint Cyber – Cyber Akademiet, 2026

Henrik Kramselund he/him han/ham hlk@zencurity.com @kramse

Slides are available as PDF, https://codeberg.org/kramse
academy-2026-day2-web-attacks-II.tex in the repo security-courses

© license CC BY 3.0. 2026 Henrik Kramselund

Goals for today



- Use assessment tools in an authorised lab: Burp Suite, OWASP ZAP, SQLmap, Nikto
- Demonstrate web attacks against a controlled vulnerable application
- Evaluate preventive controls and communicate findings

Plan for today



- Attack proxies and scanners
- Lab: OWASP Juice Shop
- Defences: CSP, CSRF tokens, secure coding
- Reporting findings

Attack proxies: Zap and Burp





OWASP recommend Zed Attack Proxy (ZAP)
https://www.owasp.org/index.php/OWASP_Zed_Attack_Proxy_Project
https://code.google.com/p/zap-extensions/

I recommend buying Burp Suite http://portswigger.net/burp/
https://pro.portswigger.net/bappstore/

Zed Attack Proxy (ZAP)



The Zed Attack Proxy (ZAP) is an easy to use integrated penetration testing tool for finding vulnerabilities in web applications.

It is designed to be used by people with a wide range of security experience and as such is ideal for developers and functional testers who are new to penetration testing.

ZAP provides automated scanners as well as a set of tools that allow you to find security vulnerabilities manually.

Source: ZAP homepage https://wiki.owasp.org/index.php/OWASP_Zed_Attack_Proxy_Project and https://www.zaproxy.org/

Burpsuite



> Burp Suite is an integrated platform for performing security testing of web applications. Its various tools work seamlessly together to support the entire testing process, from initial mapping and analysis of an application's attack surface, through to finding and exploiting security vulnerabilities.
>
> Burp gives you full control, letting you combine advanced manual techniques with state-of-the-art automation, to make your work faster, more effective, and more fun.

Burp suite contains lots of functionality proxy, spider, scanner and can be extended with Java, Python programs

http://portswigger.net/burp/
https://pro.portswigger.net/bappstore/

Sqlmap



sqlmap is an open source penetration testing tool that automates the process of detecting and exploiting SQL injection flaws and taking over of database servers. It comes with a powerful detection engine, many niche features for the ultimate penetration tester and a broad range of switches lasting from database fingerprinting, over data fetching from the database, to accessing the underlying file system and executing commands on the operating system via out-of-band connections.

Automatic SQL injection and database takeover tool http://sqlmap.org/

sqlmap features



; Features();--

- Full support for **MySQL, Oracle, PostgreSQL, Microsoft SQL Server, Microsoft Access, IBM DB2, SQLite, Firebird, Sybase, SAP MaxDB and HSQLDB** database management systems.
- Full support for six SQL injection techniques: **boolean-based blind, time-based blind, error-based, UNION query-based, stacked queries and out-of-band**.
- Support to **directly connect to the database** without passing via a SQL injection, by providing DBMS credentials, IP address, port and database name.
- Support to enumerate **users, password hashes, privileges, roles, databases, tables and columns**.
- Automatic recognition of password hash formats and support for **cracking them using a dictionary-based attack**.
- Support to **dump database tables** entirely, a range of entries or specific columns as per user's choice. The user can also choose to dump only a range of characters from each column's entry.

Not a complete list!

Source: http://sqlmap.org/

Nikto web scanner



Description Nikto is an Open Source (GPL) web server scanner which performs comprehensive tests against web servers for multiple items, including over 3200 potentially dangerous files/CGIs, versions on over 625 servers, and version specific problems on over 230 servers. Scan items and plugins are frequently updated and can be automatically updated (if desired).

Quick to run, checks quite a few things. I still use and find stuff with Nikto – and you can expand it easily

```
nikto -host 127.0.0.1 -port 8080
```

Nikto web server scanner originally from http://cirt.net/nikto2

OWASP Juice Shop Project



I will also use the OWASP Juice Shop Tool Project as a running example. This is an application which is modern AND designed to have security flaws.

Read more about this project at:
https://www.owasp.org/index.php/OWASP_Juice_Shop_Project
https://github.com/bkimminich/juice-shop

It is recommended to buy the Pwning OWASP Juice Shop Official companion guide to the OWASP Juice Shop from https://leanpub.com/juice-shop - suggested price USD 5.99

I run this as a docker container on Debian and it would be easy for most of you to get it running.

Improving the Security of your Web Applications



Start taking a critical look on your application

- Does it need to be *on the Internet* – otherwise add firewall rules!
- Does it implement HTTPS/TLS?
- What is it built using? Dependencies, frameworks, security settings
- What is the architecture – does it include a database, is the database locked down?

Content Security Policy (CSP) for XSS Prevention



The **CSP is a security configuration tool that is supported by all major browsers.** It provides settings that a developer can take advantage of to either **relax or harden security rules regarding what type of code can run inside your application.**

CSP protections come in several forms, including **what external scripts can be loaded, where they can be loaded, and what DOM APIs are allowed to execute the script**.

Let's evaluate some CSP configurations that aid in mitigating XSS risk.

- Very highly recommended, easy to check, quite easy to implement
- Tools available for you to generate even complex CSPs
- and lots of references:
  https://developers.google.com/web/fundamentals/security/csp
  https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP

Better: CSRF Tokens

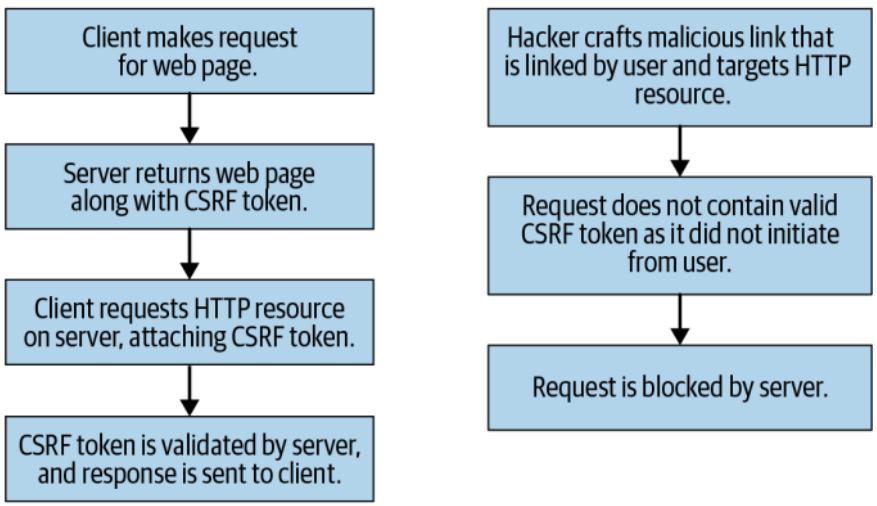


Figure 23-1. CSRF tokens, the most effective and reliable method of eliminating cross-site request forgery attacks

Source: *Web Application Security*, Andrew Hoffman, 2020, ISBN: 9781492053118

- Where do you come from, where do your browser go

Example CSRF Protection Django



Cross Site Request Forgery protection

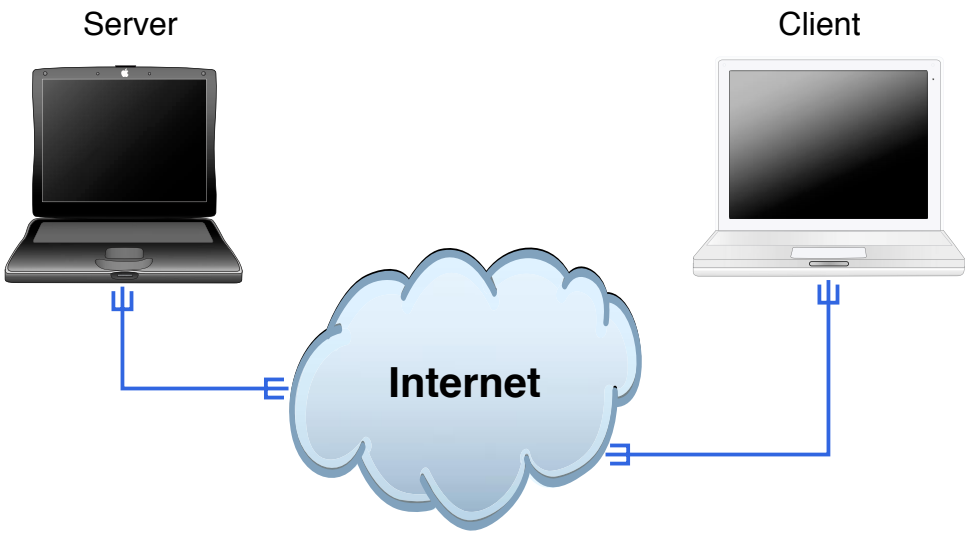
The CSRF middleware and template tag provides easy-to-use protection against Cross Site Request Forgeries. This type of attack occurs when a malicious website contains a link, a form button or some JavaScript that is intended to perform some action on your website, using the credentials of a logged-in user who visits the malicious site in their browser. A related type of attack, 'login CSRF', where an attacking site tricks a user's browser into logging into a site with someone else's credentials, is also covered.

The **first defense against CSRF attacks is to ensure that GET requests (and other 'safe' methods, as defined by RFC 7231#section-4.2.1) are side effect free**. Requests via 'unsafe' methods, such as POST, PUT, and DELETE, can then be protected by following the steps below.

Source: https://docs.djangoproject.com/en/4.1/ref/csrf/

- Many existing options can help with CSRF protection, so make sure to include this in your architecture and planning

Demo

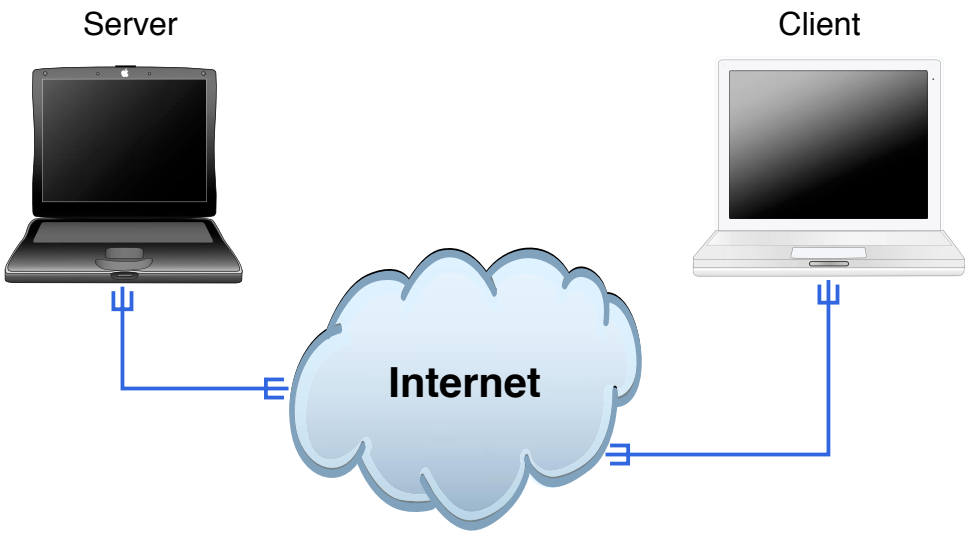


Now lets see the demo

??

which is number **??** in the exercise PDF.

Demo

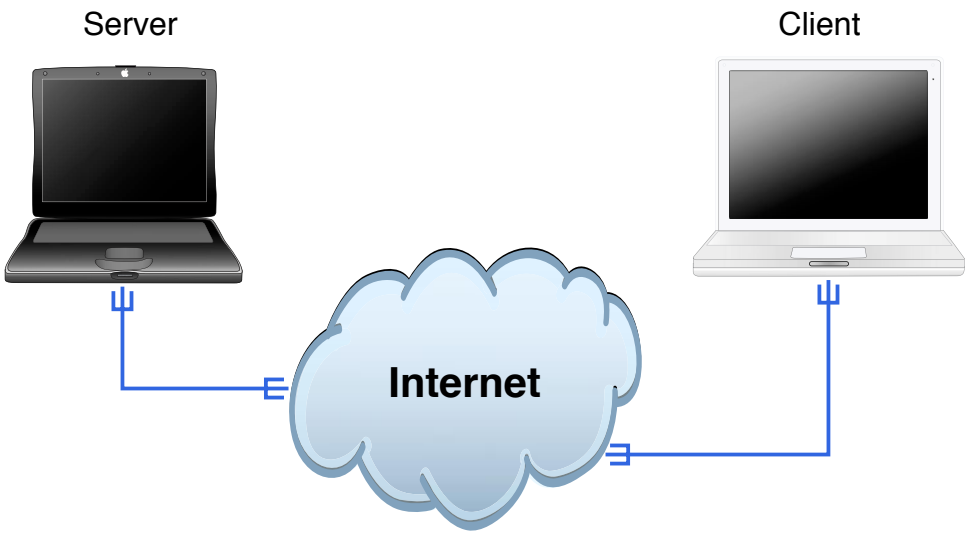


Now lets see the demo

??

which is number **??** in the exercise PDF.

Demo



Now lets see the demo

??

which is number **??** in the exercise PDF.

Reporting findings – technical & management



- **FIXME:** document evidence, impact, prioritised remediation (subject plan obj 11)

Summary & references



- Tools: Burp, ZAP, SQLmap, Nikto – used against a controlled lab (Juice Shop)
- Defences: input validation, output encoding, CSP, CSRF tokens, secure cookies
- *Web Application Security*, Andrew Hoffman, 2020, ISBN: 9781492053118 (WAS)
- Juice Shop: https://juice-shop.github.io/ – guide https://pwning.owasp-juice.shop/companion-guide/latest/